

TABLEAU DES RISQUES

Risque & Conformité

Réf.	Risque	Priorité	Preuve	Impact	Mesure	Responsable
R-01	Accès privilégiés compromis	Élevée	A-02, A-09, A-10	Réintrusion et perte de maîtrise des accès administratifs.	Suspendre les accès suspects, renforcer l'authentification et revoir les comptes privilégiés.	DSI / RSSI
R-02	Identifiants direction financière	Élevée	A-11	Accès non autorisé potentiel aux communications et données.	Sécuriser les comptes concernés et vérifier les accès.	DSI / SOC
R-03	Confidentialité / exfiltration	Élevée	A-03, A-09	Risque de divulgation d'informations.	Qualifier les données concernées, préserver les éléments utiles et engager les vérifications nécessaires.	Forensic / Juridique
R-04	Indisponibilité des services	Critique	A-01, A-12, A-13	Plusieurs systèmes internes affectés et perturbation de services essentiels.	Confiner l'incident puis restaurer les services à partir de sources vérifiées.	DSI / Continuité
R-05	Sauvegardes compromises	Critique	A-05	La restauration ne peut être considérée comme fiable sans vérification.	Tester les sauvegardes et valider chaque restauration avant reprise.	Sauvegardes / Continuité
R-06	Fraude au président / BEC	Élevée	A-23	Demande frauduleuse de virement de 480 000 MAD vers un nouvel IBAN.	Bloquer la demande et confirmer toute instruction financière par un canal indépendant.	Finance / Direction
R-07	Risque contractuel assurance cyber	Élevée	Police cyber / dossier ouvert	Risque de perte de couverture en cas de non-respect des conditions contractuelles.	Respecter les délais, conserver les preuves et obtenir les accords écrits requis.	Risque & Conformité / Direction

Cadre	Exigence	Traitement Risque & Conformité
Loi marocaine n° 09-08 – art. 23	Sécurité et confidentialité des données à caractère personnel ; protection des traitements et encadrement des sous-traitants.	Identifier les données personnelles concernées, vérifier les mesures de protection, contrôler les sous-traitants concernés et conserver les éléments de suivi.
Loi marocaine n° 05-20	Obligations de cybersécurité applicables aux entités entrant dans son champ, notamment pour les infrastructures d’importance vitale.	Déterminer le statut réglementaire d’AtlasGrid, identifier les obligations applicables et documenter les démarches de conformité.
RGPD – art. 3	Détermination du champ territorial du règlement.	Vérifier si les activités et traitements concernés entrent dans le champ du règlement et consigner la conclusion.
RGPD – art. 5(1)(f) et 32	Confidentialité, intégrité et sécurité appropriée des traitements.	Évaluer les mesures de protection en place, relever les écarts et formaliser les actions correctives.
RGPD – art. 33	Notification à l’autorité de contrôle en cas de violation de données personnelles lorsque les conditions prévues sont réunies.	Qualifier la violation, déterminer l’obligation de notification, documenter la décision et respecter le délai réglementaire.
RGPD – art. 34	Information des personnes concernées lorsque la violation présente un risque élevé pour leurs droits et libertés.	Évaluer le niveau de risque pour les personnes concernées et préparer l’information requise lorsque les conditions sont réunies.
Police d’assurance cyber	Déclaration du sinistre sous 48 heures et accord écrit préalable pour les dépenses majeures soumises à cette clause.	Archiver la déclaration et la confirmation de l’assureur, suivre les conditions contractuelles et obtenir les accords écrits requis.

Délais à distinguer :

Cadre	Traitement
Assurance cyber	Déclaration sous 48 heures ; conservation de la confirmation de l’assureur et respect des conditions contractuelles avant toute dépense concernée.
Autorité du scénario	Premiers éléments transmis sous 72 heures ; conserver l’accusé de réception et compléter le dossier avec les informations nouvelles.
RGPD	Le délai de 72 heures de l’article 33 s’applique lorsque le RGPD est applicable et que l’obligation de notification est déclenchée.
Loi marocaine 09-08 / 05-20	Vérifier le champ d’application au regard du statut d’AtlasGrid, des données concernées et des activités exercées, puis documenter les démarches réalisées.